

Title of Issue

Blind OS Command Injection with Time Delays

Description

The application's feedback submission form is vulnerable to blind OS command injection. Unlike reflected command injection where output is returned in the HTTP response, this variant is "blind" — the attacker receives no direct output from the injected command. However, command execution can be confirmed by observing a measurable time delay in the server's response.

User input from the `email` field is passed unsanitized to a backend shell command. By injecting the `ping` utility with a specified count, the attacker can cause the server to delay its response by a predictable number of seconds, conclusively demonstrating arbitrary command execution.

Affected Endpoint: `POST /feedback/submit` **Vulnerable Parameter:** `email`

Steps to Exploit

1. Navigate to the feedback submission page at `/feedback`.
2. Fill in all required form fields (name, subject, message) with arbitrary values.
3. In the **email** field, enter the following time-delay payload:

```
x||ping -c 10 127.0.0.1||
```

4. Submit the form.
 5. Observe that the server takes approximately **10 seconds** to respond — corresponding to 10 ICMP echo requests to `127.0.0.1`.
 6. The delayed response confirms that the `ping` command was executed server-side.
-

Proof of Concept

Payload (email field):

```
x||ping -c 10 127.0.0.1||
```

HTTP Request:

```
POST /feedback/submit HTTP/1.1
Host: <lab-id>.web-security-academy.net
Content-Type: application/x-www-form-urlencoded

csrf=<token>&name=test&email=x||ping+-c+10+127.0.0.1||&subject=test&message=test
```

Observed Behaviour:

- Without payload: response returns in ~200ms.
- With payload: response delayed by ~10,000ms (10 seconds), confirming 10 ICMP packets were sent.

Operator explanation: The double pipe (`||`) is a shell OR operator — it executes `ping` only if the preceding command (`x`) fails (which it always will, since `x` is not a valid command). The trailing `||` prevents a parse error in the shell. The net effect is: `ping -c 10 127.0.0.1` is executed unconditionally.

Impact

- Confirmed Remote Code Execution on the server, even without visible output.
 - Using time-based exfiltration techniques, an attacker can extract sensitive data character by character (e.g., `ping -c $(whoami | cut -c 1 | od -d | head -1 | awk '{print $2}')` `127.0.0.1`).
 - Can be escalated to out-of-band data exfiltration via DNS or HTTP callbacks using tools like Burp Collaborator.
 - Enables persistent backdoor installation or further lateral movement.
-

Mitigation / Remediation

1. **Do not pass user-supplied data to OS commands.** Use language-native mail libraries (e.g., `sendmail` API, SMTP libraries) instead of shell-based mail utilities.
 2. **If shell execution is unavoidable**, sanitize all input by stripping or escaping shell metacharacters before use.
 3. **Implement strict input validation** — an email field should only accept RFC 5321-compliant email addresses.
 4. **Apply network egress restrictions** to prevent outbound DNS/ICMP/HTTP callbacks from the server.
 5. **Run processes under minimal OS privileges** to limit the impact of any successful exploitation.
-

CVSS Score

CVSS v3.1 Score: 7.5 (High) `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Exploitable remotely via form submission
Attack Complexity	Low	Simple payload, no prior access required
Privileges Required	None	Feedback form is unauthenticated
User Interaction	None	No victim interaction required
Scope	Unchanged	Impact within the server process boundary
Confidentiality Impact	High	Blind injection can exfiltrate data out-of-band
Integrity Impact	None	Time-delay technique alone does not modify data
Availability Impact	None	No denial-of-service observed in this scenario